

Proyecto: Inicio de sesión con bloqueo de cuenta por intentos fallidos

Versión: 1.0

Fecha: 26/8/2026

1. Objetivo

Validar que el módulo de autenticación del Portal Corporativo Aurora permita a los usuarios registrados iniciar sesión correctamente con credenciales válidas y sea redirigidos a su panel de trabajo, al tiempo que verifique la correcta implementación del mecanismo de protección contra fuerza bruta mediante bloqueo temporal de cuenta tras 3 intentos fallidos consecutivos. Se busca confirmar que el conteo de intentos, la activación y expiración del bloqueo de 15 minutos, y los mensajes mostrados al usuario funcionen de forma consistente y segura, sin exponer información sensible ni afectar el acceso legítimo de los usuarios una vez cumplido el periodo de bloqueo.

2. Alcance

2.1 Dentro del Alcance

1. Validación del flujo de login con credenciales correctas y redirección al Dashboard mostrando el nombre del usuario.
2. Validación del mensaje genérico de error ante contraseña incorrecta con usuario existente.
3. Validación del mensaje genérico de error ante usuario no registrado, confirmando que no se distinga del caso de contraseña incorrecta.
4. Validación del conteo de intentos fallidos consecutivos por cuenta y activación del bloqueo exactamente en el tercer intento.
5. Validación del mensaje de bloqueo con indicación de 15 minutos de espera.
6. Validación del comportamiento del sistema cuando se ingresan credenciales correctas durante el periodo de bloqueo activo.
7. Validación del reinicio del contador de intentos fallidos tras un login exitoso.
8. Validación de la expiración del bloqueo tras 15 minutos y la reanudación de la evaluación normal de credenciales.
9. Validación de que los intentos fallidos posteriores a la expiración del bloqueo inicien un nuevo ciclo de conteo.
10. Validación del comportamiento del formulario ante envíos con campos vacíos o mal formados.

2.2 Fuera del Alcance

1. Bloqueo o limitación de intentos por dirección IP o dispositivo (no contemplado en el requerimiento).
2. Mecanismo de desbloqueo manual por parte de soporte o administración (no descrito en el requerimiento).
3. Pruebas de carga o estrés sobre el módulo de autenticación.
4. Validación de condiciones de carrera bajo solicitudes de login concurrentes (identificado como riesgo, no como alcance funcional a probar en este ciclo).
5. Integración con sistemas externos de identidad (SSO, MFA) al no estar mencionados en el requerimiento.
6. Gestión de sesión posterior al login exitoso (expiración de sesión, cierre de sesión, permisos del Dashboard).

3. Supuestos

- Existe un ambiente de pruebas con al menos una cuenta de usuario registrada y válida disponible para la ejecución de los escenarios (usuario.valido@aurora.com).
- El equipo de desarrollo provee un mecanismo (backend/mock) para simular o adelantar el paso del tiempo, dado que esperar 15 minutos reales por cada escenario de expiración de bloqueo no es operativamente viable en cada ciclo de regresión.
- El campo identificador de cuenta es el correo corporativo, y el conteo de intentos fallidos se asocia a dicho identificador según lo indicado en las reglas de negocio.
- No existen validaciones adicionales de seguridad (como CAPTCHA o MFA) que interfieran con el flujo de login descrito en la historia de usuario.
- El ambiente de pruebas refleja la lógica de negocio descrita, incluyendo la persistencia del contador de intentos y el estado de bloqueo por cuenta.

4. Riesgos

4.1 Riesgos Funcionales

- El bloqueo no se activa exactamente en el tercer intento fallido por un error de comparación en el conteo (off-by-one), permitiendo un cuarto intento antes de bloquear o bloqueando prematuramente en el segundo.
- El temporizador de bloqueo no libera la cuenta correctamente pasados los 15 minutos por manejo incorrecto de zona horaria o del reloj del servidor, dejando a usuarios legítimos bloqueados indefinidamente.
- El mensaje de error expone información diferenciada entre usuario inexistente y contraseña incorrecta por inconsistencia entre frontend y backend, habilitando enumeración de cuentas.
- El contador de intentos fallidos no se reinicia correctamente tras un login exitoso, arrastrando conteos previos que provocan bloqueos inesperados en ciclos posteriores.
- Los intentos fallidos posteriores a la expiración de un bloqueo previo arrastran el conteo del ciclo anterior en lugar de iniciar un nuevo ciclo desde cero.

4.2 Riesgos de Negocio

- Bloqueos legítimos no resueltos oportunamente pueden generar un aumento de solicitudes a mesa de ayuda, dado que el requerimiento no contempla un mecanismo de desbloqueo manual, afectando la productividad de los usuarios del portal corporativo.
- Una falla en la lógica de bloqueo (activación tardía o inexistente) dejaría expuestas las cuentas de todos los usuarios registrados a ataques de fuerza bruta, comprometiendo la seguridad del acceso corporativo.

5. Estrategia de Pruebas

La estrategia de pruebas se ejecutará en un ciclo funcional completo sobre el módulo de autenticación, cubriendo primero los flujos positivos de acceso y posteriormente los escenarios negativos y de borde asociados al mecanismo de bloqueo por intentos fallidos, priorizando la validación exacta del umbral de tres intentos y la ventana de 15 minutos por ser los puntos de mayor riesgo identificados. La ejecución se realizará sobre el ambiente de pruebas designado por el cliente, replicando en la medida de lo posible las condiciones de uso real del portal corporativo. Dado que el módulo introduce estado persistente por cuenta (contador de intentos y estado de bloqueo), se incluirá un ciclo de regresión focalizada sobre los flujos de login existentes para confirmar que la nueva lógica de bloqueo no altere el comportamiento de autenticación previamente validado. Los defectos detectados se clasificarán según su severidad y se reportarán al equipo de desarrollo para su corrección, ejecutando los reintentos correspondientes hasta el cierre de los hallazgos críticos y altos antes de dar por finalizado el ciclo.

6. Tipos y Niveles de Pruebas

6.1 Tipos de Pruebas

1. Pruebas funcionales

- Login exitoso con credenciales válidas y redirección al Dashboard
- Activación del bloqueo exactamente en el tercer intento fallido
- Reinicio del contador de intentos tras login exitoso
- Expiración del bloqueo tras 15 minutos y reanudación de evaluación normal

2. Pruebas de integracion

- Persistencia correcta del contador de intentos y estado de bloqueo asociado a la cuenta del usuario
- Consistencia entre frontend y backend en la visualización del mensaje de bloqueo vs. mensaje de credenciales incorrectas
- Comunicación entre el módulo de autenticación y la gestión de sesión al conceder acceso

3. Pruebas negativas

- Login fallido con contraseña incorrecta para usuario existente
- Login fallido con usuario no registrado, verificando mensaje genérico idéntico
- Intento con credenciales correctas durante el periodo de bloqueo activo
- Envío del formulario con campos vacíos o mal formados

4. Pruebas de regresion focalizada

- Flujo de login exitoso previo a la introducción del bloqueo (validar que no se haya alterado)
- Visualización del nombre de usuario en el Dashboard tras acceso concedido
- Comportamiento del formulario de login ante entradas ya validadas anteriormente (formato de correo, campos requeridos)

6.2 Niveles de Pruebas

1. Pruebas de sistema

- Validación end-to-end del flujo de login, conteo de intentos fallidos, activación y expiración del bloqueo, y mensajes mostrados en la UI de login

2. Pruebas de integracion

- Validación de la persistencia del contador de intentos y estado de bloqueo por cuenta entre el módulo de autenticación y la capa de datos

3. Pruebas de aceptacion (UAT)

- Confirmación por parte del cliente de que el flujo de acceso legítimo y el mecanismo de bloqueo tras 3 intentos fallidos cumplen con la expectativa de seguridad y usabilidad definida en la historia de usuario

7. Criterios de Entrada y de Salida

7.1 Criterios de Entrada

- El ambiente de pruebas está disponible y estable, con al menos una cuenta de usuario registrada para la ejecución de los escenarios.
- La funcionalidad de login y bloqueo de cuenta se encuentra desplegada en el ambiente de pruebas y accesible para su validación.
- Los criterios de aceptación de la historia de usuario han sido revisados y están disponibles como referencia para el diseño de casos de prueba.

- Se cuenta con un mecanismo para simular o adelantar el paso del tiempo, necesario para validar la expiración del bloqueo de 15 minutos.

7.2 Criterios de Salida

- Todos los escenarios de prueba definidos en el alcance han sido ejecutados.
- No existen defectos abiertos de severidad crítica o alta relacionados con la activación del bloqueo, su expiración, o la exposición de información en los mensajes de error.
- El comportamiento de bloqueo en el tercer intento fallido y su liberación tras 15 minutos ha sido validado exitosamente.
- Los defectos de severidad media o baja identificados han sido documentados y comunicados al cliente para su priorización, sin bloquear el cierre del ciclo.

8. Responsables

Equipo	Cargo / Rol	Contacto
TestiALab		
Cliente		
Proveedor de Desarrollo		